CyberGuard-RAG

A Retrieval-Augmented Cybersecurity Advisor with Tool-Using Agent

Capstone Project Report

From Tokens to Transformers: A Course on GenAI x LLM Mastery

Consulting & Analytics Club, IIT Guwahati

Author: Nilavan

Institution: Sri Sairam Engineering College, Chennai (B.E. Computer Science Engineering)

Submission date: 01 November 2026

Source code: [PASTE YOUR GITHUB LINK HERE]

1. Problem Statement

Online fraud (phishing, UPI scams, 'digital arrest' calls) harms users who need quick, trustworthy guidance. General-purpose language models can answer such questions but may hallucinate procedures, helpline numbers or legal claims. This project builds a **grounded** assistant: every answer is assembled only from a curated cybersecurity knowledge base, cites its source document, and is complemented by an agentic tool that scores suspicious URLs.

2. Objectives

(a) Apply the course pipeline of chunking, representation and retrieval to a security knowledge base. (b) Ground answers in retrieved evidence and refuse out-of-scope questions. (c) Add an agent layer that routes a query to tools (retriever and URL-risk checker). (d) Evaluate retrieval quantitatively and analyse failures.

3. System Architecture

```
User query
   |
   v
[Agent router] --finds URL?--> [url_risk tool: IP host, shortener, risky TLD,
   |                              brand-on-unofficial-domain, HTTPS check]
   v
[Retriever: TF-IDF (1-2 grams) + cosine similarity, top-k chunks]
   |
   v
[Answer composer: grounded extractive answer with [source] citations]
   |   (optional LLM hook: context-only prompt, treats retrieved text as data)
   v
Answer + sources + tool results + execution trace
```

4. Implementation

Knowledge base. Eight curated documents covering phishing, UPI/payment fraud, passwords and MFA, ransomware, network security, web vulnerabilities, social engineering and LLM security (14 chunks).

Chunking. Sentence-aware packing of roughly 60 words per chunk, so no sentence is cut in half; each chunk keeps its title and source file as metadata.

Retrieval. Chunks are embedded with a sparse TF-IDF vectoriser (unigrams and bigrams, English stop-words removed, sublinear term frequency). Queries are matched by cosine similarity and the top-3 chunks are returned. URLs are stripped from the query before retrieval so that domain tokens do not pollute matching.

Agent and tools. The agent detects URLs in the query and calls *url_risk*, a heuristic scorer returning LOW/MEDIUM/HIGH with human-readable reasons. Retrieval and tool outputs are merged in the final answer, and a trace of every call is returned for transparency.

Grounding and refusal. Sentences are ranked by lexical overlap with the query and only evidence from retrieved chunks is used. If the best similarity score is below 0.05, the system replies that the answer is not in the knowledge base instead of guessing. The optional LLM prompt instructs the model to answer only from context and to treat context as data, mitigating prompt injection.

5. Evaluation

A gold-labelled set of 18 questions was written, each mapped to the document that contains the answer. Metrics are hit@k: whether the correct document appears in the top-k retrieved chunks.

Metric	Value
Documents / chunks	8 / 14
Evaluation queries	18
hit@1 (TF-IDF retriever)	88.9% (16/18)
hit@3 (TF-IDF retriever)	100.0%
Random-choice hit@1 baseline	12.5%

Qualitative demonstrations.

Q: Is http://paytm-kyc-update.xyz/login safe? I got an SMS asking for my OTP

A: Authenticator apps and hardware security keys are stronger than SMS OTP because SIM-swap attacks can intercept SMS codes. [password_mfa.md] Phishing is a social-engineering attack where an attacker impersonates a trusted entity such as a bank, courier or government office to trick a victim into revealing credentials, OTPs or payment details. [phishing.md] Common signs: urgent language, mismatched sender domain, misspelled brand names in the URL, shortened links, requests for OTP or password, and unexpected attachments. [phishing.md] URL check for paytm-kyc-update.xyz: HIGH risk (high-abuse top-level domain; many hyphens in domain; brand name 'paytm' used on unofficial domain; no HTTPS).

Trace: retrieve(k=3) -> ['password_mfa.md', 'social_engineering.md', 'phishing.md']; url_risk(paytm-kyc-update.xyz) -> HIGH

Q: What is the best way to cook biryani?

A: I could not find this in the knowledge base.

Trace: retrieve(k=3) -> ['web_vulns.md', 'upi_fraud.md', 'upi_fraud.md']

Q: I got a call saying I am under digital arrest, what do I do?

A: "Digital arrest" scams threaten victims with fake legal action and demand money transfers. [social_engineering.md] No genuine agency conducts arrests or investigations over video call or demands payment to clear a case. [social_engineering.md] If defrauded, immediately call the bank, block cards and UPI, and file a complaint on the national cybercrime helpline 1930 or cybercrime.gov.in as soon as possible because early reporting improves the chance of freezing funds. [upi_fraud.md]

Trace: retrieve(k=3) -> ['social_engineering.md', 'web_vulns.md', 'upi_fraud.md']

6. Error Analysis

Two queries missed at rank 1 but were recovered within the top-3. 'Which number do I call to report cyber fraud in India?' shares the term 'fraud' with several documents and is semantically a reporting question, ranked first against the phishing document. 'How do scammers misuse QR codes for payments?' uses vocabulary ('misuse', 'scammers') that differs from the source text ('scammer sends a collect request or QR code'). Both failures are vocabulary-mismatch problems typical of sparse retrieval, which dense embeddings address.

The out-of-scope question ('What is the best way to cook biryani?') was correctly refused, showing that the similarity threshold provides basic hallucination control. The URL example demonstrates the agent combining retrieved advice with an independent tool signal.

7. Limitations

The knowledge base is small and hand-written; TF-IDF cannot capture synonyms; the extractive composer does not paraphrase; the URL scorer is heuristic and does not query live threat-intelligence feeds; the evaluation set is small, so reported percentages carry wide uncertainty and should be read as indicative, not as a benchmark.

8. Future Work

Replace TF-IDF with dense sentence embeddings and a hybrid (BM25 + dense) retriever with a cross-encoder re-ranker; plug an LLM into the existing hook for fluent, cited answers; add faithfulness evaluation (answer-to-evidence entailment); support vernacular languages; add tools for WHOIS age and certificate checks; and expand the knowledge base with official advisories (e.g., CERT-In).

9. Conclusion

CyberGuard-RAG demonstrates the full RAG-plus-agent workflow from the course: preprocessing and chunking, vector retrieval, grounded generation with citations, refusal behaviour, tool use, and measured evaluation with honest error analysis. The code is reproducible with a single command and is structured so that an LLM can be added without changing the pipeline.

10. Reproducibility

Repository layout: `kb/` (documents), `src/rag.py` (pipeline), `src/evaluate.py` (evaluation), `src/app.py` (CLI). Run `pip install -r requirements.txt` then `python src/evaluate.py`.